

Educação Profissional Paulista

Técnico em
**Ciência
de Dados**



**GOVERNO DO ESTADO
DE SÃO PAULO**

Privacidade e Lei Geral de Proteção de Dados

Conformidade e auditoria

Aula 2

Código da aula: [DADOS]ANO2C6B2S13A2



Exposição



Objetivos da Aula

- Introduzir os conceitos elementares de privacidade e de proteção de dados.



Competências da Unidade (Técnicas e Socioemocionais)

- Compreender e dominar os princípios da privacidade e da proteção de dados e como aplicá-los na construção de algoritmos de Inteligência Artificial;
- Analisar situações complexas, avaliar diferentes perspectivas e prever as consequências de decisões e de ações;
- Entender os atuais desafios da Lei Geral de Proteção de Dados no ambiente da IA.



Recursos Didáticos

- Recurso audiovisual para exibição de textos, de vídeos e de imagens;
- Artigos selecionados para leitura;
- Acesso ao laboratório de informática e/ou à internet.



Duração da Aula

50 minutos

Exposição



© Getty Images

Auditoria de dados e resposta a incidentes

Importância da auditoria de dados

As auditorias de dados são essenciais para verificar a conformidade com as políticas de proteção de dados e identificar áreas de risco que necessitam de melhoria. Elas ajudam a garantir que as práticas de processamento de dados estejam alinhadas com a LGPD e com outras regulamentações relevantes.

Exemplo: Uma empresa de varejo online realiza uma auditoria de dados e descobre que alguns dos seus sistemas de pagamento armazenam dados de cartão de crédito de forma inadequada, contrariando as normas de segurança de dados. Como resultado, a empresa implementa medidas corretivas, como a criptografia de dados de pagamento e a adoção de soluções de pagamento de terceiros para melhorar a segurança.

Exposição

Auditoria de dados e resposta a incidentes

Processo de auditoria de dados

O processo de auditoria de dados inclui várias etapas, como a identificação de dados processados, a análise de riscos, a avaliação de políticas de privacidade, a verificação da segurança dos dados e a análise de como os dados são coletados, armazenados, processados e descartados.

Exemplo: Durante uma auditoria em uma instituição financeira, auditores identificam que a política de retenção de dados está desatualizada, mantendo informações de clientes por mais tempo que o necessário. A auditoria leva a uma revisão e a uma atualização da política de retenção de dados, assegurando que a instituição cumpra com os princípios de minimização e limitação de conservação da LGPD.



© Getty Images

Resposta a incidentes de segurança

Ter um plano de resposta a incidentes de segurança é crucial para mitigar os danos causados por vazamentos ou por violações de dados. Este plano deve incluir procedimentos para a detecção rápida de incidentes, comunicação eficaz com todas as partes interessadas e medidas para prevenir futuras ocorrências.

Exemplo: Uma empresa de tecnologia sofre um ataque cibernético que resulta no acesso não autorizado a dados pessoais de usuários. Graças ao seu plano de resposta a incidentes, a empresa consegue detectar rapidamente o ataque, isolar os sistemas afetados para limitar o dano, notificar os usuários afetados e as autoridades competentes em tempo hábil e tomar medidas para reforçar suas defesas contra ataques futuros.

Exposição



© Getty Images

Auditoria de dados e resposta a incidentes

Gerenciamento de consentimento

O gerenciamento de consentimento refere-se à prática de obter, registrar e gerenciar o consentimento dos titulares dos dados de maneira clara e conforme as normas. É fundamental assegurar que o consentimento seja específico, informado e revogável a qualquer momento.

Exemplo: Um aplicativo de saúde introduz um novo recurso que requer acesso a dados de localização dos usuários. Para estar em conformidade, o aplicativo implementa um sistema de gerenciamento de consentimento que solicita aos usuários que concordem explicitamente com o novo uso de seus dados, fornecendo informações claras sobre o propósito e permitindo a revogação do consentimento a qualquer momento.

Avaliação de Impacto à Proteção de Dados (AIPD)

A AIPD é um processo que ajuda a identificar e a minimizar os riscos de privacidade de projetos de processamento de dados. É particularmente necessária em novas operações de processamento que possam resultar em riscos elevados para os direitos e liberdades dos indivíduos.

Exemplo: Uma universidade planeja adotar um sistema de aprendizado à distância que envolve a coleta e a análise de grandes volumes de dados dos estudantes para personalizar o conteúdo educacional. Antes da implementação, realiza-se uma AIPD, que identifica riscos potenciais à privacidade dos estudantes e recomenda medidas de mitigação, como a anonimização de dados e a limitação do acesso aos dados.

Notificação de violação de dados

A notificação de violação de dados é um requisito legal sob a LGPD, que obriga as organizações a informar, tanto a autoridade de proteção de dados quanto os titulares dos dados afetados, em caso de violação de dados que possa resultar em riscos aos seus direitos e liberdades.

Exemplo: Uma empresa de comércio eletrônico detecta uma violação de segurança que expôs dados pessoais de clientes. A empresa rapidamente avalia o incidente para entender sua extensão e impacto. Em seguida, notifica a ANPD e os clientes afetados dentro do prazo legal, oferecendo orientações sobre como proteger suas informações e mitigar possíveis danos.

Exposição



© Getty Images

Auditoria de dados e resposta a incidentes

Princípio da Limitação de Finalidade

Este princípio determina que os dados pessoais devem ser coletados apenas para finalidades específicas, explícitas e legítimas, não sendo posteriormente processados de maneira incompatível com essas finalidades.

Exemplo: Uma empresa de pesquisa de mercado coleta dados de consumidores sob o pretexto de uma pesquisa sobre hábitos alimentares, mas depois utiliza esses dados para enviar publicidade direcionada. Isso viola o princípio da limitação de finalidade, pois os dados estão sendo usados para uma finalidade não declarada originalmente.

Auditoria de dados e resposta a incidentes

Segurança dos dados

Refere-se à implementação de medidas técnicas e organizacionais adequadas para proteger dados pessoais contra perda, alteração, tratamento ou acesso não autorizado, garantindo a integridade e a confidencialidade dos dados.

Exemplo: Uma clínica médica implementa múltiplas camadas de segurança, incluindo criptografia de dados, autenticação de dois fatores para acesso a registros médicos eletrônicos e treinamento regular de funcionários sobre práticas seguras de manipulação de dados para proteger as informações sensíveis dos pacientes.

Auditoria de dados e resposta a incidentes

Direitos dos titulares dos dados

Os titulares dos dados têm diversos direitos sob a LGPD, incluindo o direito de acesso, correção, exclusão, portabilidade dos dados, bem como o direito de se opor ao processamento de seus dados.

Exemplo: Um consumidor descobre que uma loja online possui informações incorretas sobre seu endereço. Ele exerce seu direito de correção sob a LGPD, solicitando à loja que atualize seus dados. A loja deve atender a essa solicitação prontamente e confirmar a correção ao consumidor.

Auditoria de dados e resposta a incidentes

Legítimo interesse

É uma das bases legais para o processamento de dados pessoais que permite às organizações processar dados sem consentimento explícito se o processamento for necessário para os interesses legítimos da organização ou de terceiros, desde que esses interesses não se sobreponham aos direitos e às liberdades do titular dos dados.

Exemplo: Um banco utiliza dados de transações de clientes para detectar e prevenir fraudes financeiras. Este processamento é considerado baseado no legítimo interesse do banco e dos clientes em proteger suas contas e seus ativos contra atividades fraudulentas, desde que seja feito de maneira que respeite a privacidade dos clientes.



Vamos
fazer uma
atividade

Estudo de caso: vazamento de dados em uma rede de varejo

Contexto:

Uma grande rede de varejo, conhecida por suas lojas físicas e presença online, enfrentou recentemente um significativo vazamento de dados. Informações sensíveis, incluindo dados de cartão de crédito, endereços residenciais e histórico de compras de milhares de clientes, foram expostas devido a uma falha de segurança em seu sistema de gerenciamento de dados.

A falha foi explorada por cibercriminosos, que acessaram e divulgaram os dados online. A rede de varejo identificou o vazamento após receber alertas de uma empresa de segurança cibernética, e confirmou a extensão do problema após uma investigação interna.

Situação fictícia elaborada especialmente para o curso.



Vamos
fazer uma
atividade

Estudo de caso: vazamento de dados em uma rede de varejo

Desdobramentos:

Após a descoberta, a rede de varejo agiu rapidamente para conter o vazamento, notificou os clientes afetados e as autoridades regulatórias, e iniciou uma campanha para orientar os clientes sobre como proteger suas informações. Além disso, contratou uma empresa de segurança de terceiros para auditar seus sistemas e implementar melhorias na segurança dos dados. A empresa também revisou suas políticas de privacidade e procedimentos de consentimento para garantir conformidade com a LGPD.



Vamos
fazer uma
atividade

Estudo de caso: vazamento de dados em uma rede de varejo

- 1 Quais **falhas de conformidade** com a LGPD podem ser identificadas neste caso?
- 2 Como a rede de varejo deveria gerenciar o **consentimento dos clientes** para estar em conformidade com a LGPD após a revisão de suas **políticas**?
- 3 Quais medidas a rede de varejo deve implementar para **prevenir** futuros **vazamentos de dados** e **garantir a segurança** das informações dos clientes?

Resolva, em grupo, o estudo de caso, respondendo às três perguntas ao lado.

 20 min

 Em grupo

Elabore as respostas e envie pelo AVA.



© Getty Images

O que nós
**aprendemos
hoje?**

Hoje desenvolvemos:

- 1** Compreensão sobre a auditoria de dados e resposta a incidentes de segurança.
- 2** Conhecimento sobre as melhores práticas para responder a vazamentos de dados.
- 3** Aplicação de conceitos da LGPD em cenários reais por meio de estudo de caso.

Saiba mais

A cibersegurança, também chamada de segurança de computadores ou segurança da tecnologia da informação, abrange técnicas e ações que tem como objetivo proteger sistemas, programas, equipamentos, redes e pessoas de ataques cibernéticos, de crimes virtuais e de terrorismo cibernético. Leia mais sobre o tema clicando no link abaixo:

BOCK, M. M. O que é cibersegurança: práticas e as equipes de segurança. *Alura*, 2022. Disponível em: <https://www.alura.com.br/artigos/o-que-e-ciberseguranca-praticas-equipes-de-seguranca>
Acesso em: 22 mar. 2024.

Referências da aula

BRASIL. Ministério da Justiça e Segurança Pública. Autoridade Nacional de Proteção de Dados. Perguntas Frequentes – ANPD, 2023. Disponível em:

<https://www.gov.br/anpd/pt-br/acesso-a-informacao/perguntas-frequentes-2013-anpd>. Acesso em: 22 mar. 2024.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 22 mar. 2024.

FRAZÃO, A., CARVALHO, A. P., MILANEZ, G., *Curso de Proteção de Dados: fundamentos da LGPD*. São Paulo: Editora Forense, 2022.

MALDONADO, V. N., *LGPD – Lei Geral de Proteção de Dados Pessoais: Manual de Implementação*. São Paulo: Revista dos Tribunais, 2022.

Identidade visual: imagens © Getty Images

Educação Profissional Paulista

Técnico em
**Ciência
de Dados**



**GOVERNO DO ESTADO
DE SÃO PAULO**